SECCIÓN 4.3

Ejecución inicial y abuso de interacción del usuario

Temas de esta sección:

- Qué es la ejecución inicial y por qué empieza con el usuario
- Phishing como inicio de la cadena: cómo se ve en SOC
- Adjuntos maliciosos: extensiones, formatos y señales
- Documentos Office y procesos hijos sospechosos
- Archivos comprimidos, ISO, LNK y scripts
- Instaladores falsos, ingeniería social y señales fuertes
- Ejemplos: adjunto con macro, descarga desde navegador, phishing de credenciales

4.3 | La ejecución inicial no siempre parece 'malware detectado'

En SOC real, la ejecución inicial no siempre aparece con una alerta clara. A veces se ve como:

```
Suspicious PowerShell execution
```
→ Proceso anómalo iniciado por Office

```
Office spawned child process
```
→ Adjunto que ejecutó algo

```
Executable downloaded from browser
```
→ Archivo descargado y ejecutado

```
Script executed from Temp
```
→ Script en ruta temporal

```
User clicked suspicious URL
```
→ Enlace de phishing

```
File created in AppData
```
→ Archivo en ruta de usuario

La pregunta clave: ¿Qué acción permitió que esta actividad comenzara dentro del entorno?

El analista no debe esperar a ver 'Initial Access confirmed'. Debe interpretar señales y reconstruir cómo empezó la actividad.

4.3 | Phishing como inicio de la cadena: cómo se ve en SOC

El phishing es el vector de acceso inicial más frecuente. En SOC no siempre aparece como 'phishing detectado':

Tipo de phishing	Señal en SOC	Implicancia
Phishing con adjunto malicioso	*Email recibido + WINWORD.EXE → powershell.exe + conexión externa*	Alta prioridad — adjunto ejecutó proceso hijo
Phishing de credenciales (link)	*URL clickeada → login en sitio falso → login exitoso desde IP extranjera + nuevo device*	Sin malware en endpoint — análisis de identidad
Spear phishing (dirigido)	*Adjunto con nombre específico del destinatario (proyecto, factura del cliente) + proceso hijo*	Mayor probabilidad de acción — usuario específico
Phishing de MFA / AiTM	*Login exitoso con MFA desde IP desconocida → nuevo device → regla de reenvío creada*	MFA exitoso no descarta compromiso

⚠ **El phishing de credenciales no genera malware en endpoint. La cadena se analiza desde identidad: login anómalo → actividad posterior → impacto.**

Los adjuntos son uno de los vectores más frecuentes. El formato del archivo da contexto:

Archivo adjunto	Tipo	Señal de riesgo
`Factura.docm`	**Macro Office**	*Puede ejecutar PowerShell o cmd como proceso hijo*
`Comprobante.pdf.exe`	**Extensión doble**	*El usuario cree que es PDF, en realidad es ejecutable*
`Orden_de_pago.zip`	**ZIP con payload**	*Puede contener .exe, .lnk, .js o .iso internamente*
`Liquidacion.iso`	**Imagen de disco**	*Se monta automáticamente y expone LNK malicioso*
`CV_Candidato.lnk`	**Acceso directo**	*Ejecuta comandos ocultos, puede iniciar PowerShell*
`Documento.html`	**Phishing HTML**	*Puede redirigir a página falsa o ejecutar JS malicioso*

⚠ Señal fuerte: Office → PowerShell con parámetros ocultos
Parent: WINWORD.EXE → Child: powershell.exe → CommandLine: powershell -nop -w hidden -enc <base64>

4.3 | Señales fuertes de ejecución inicial

Algunas combinaciones requieren análisis prioritario:

`Office → PowerShell`	**ALTA**	`Office → cmd.exe`	**ALTA**
`Outlook → script`	**ALTA**	`Browser → executable → conexión externa`	**MEDIA-ALTA**
`LNK → PowerShell`	**MEDIA-ALTA**	`ISO montado → LNK ejecutado`	**MEDIA-ALTA**
`Script → download → execute`	**ALTA**	`HTML phishing → login inusual`	**ALTA**

Ejemplo crítico:
OUTLOOK.EXE → WINWORD.EXE → powershell.exe → dominio externo → archivo creado
Cuantas más piezas se conectan, más fuerte es la hipótesis. No se analiza por un único evento, sino por la cadena.

Los atacantes engañan al usuario haciéndole creer que ejecuta algo legítimo:

Tipos de instaladores falsos

- Software legítimo reempaquetado con malware (bundle)
- Instalador de Adobe, VLC, 7-Zip con payload incluido
- Crack o keygen que ejecuta malware al activar
- Actualización falsa ('Update Chrome Now')
- Setup.exe enviado por correo o descargado desde URL acortada
- Instalador con nombre de herramienta corporativa

Señales en SOC

- Executable ejecutado desde Downloads sin firma
- Proceso padre: chrome.exe o edge.exe → setup.exe → powershell
- Instalador crea procesos hijos inesperados
- Archivo sin firma en ruta de usuario
- Conexión externa después de ejecutar el instalador
- Binario no conocido con nombre genérico (update.exe, install.exe)

⚠ **La ingeniería social no deja rastro técnico directo. La señal es el comportamiento posterior: proceso hijo, conexión externa, persistencia.**

4.3 | Tres ejemplos aplicados

Tres formas distintas de ejecución inicial — tres análisis distintos:

MACRO EN DOCUMENTO	DESCARGA DESDE NAVEGADOR	PHISHING DE CREDENCIALES

`User: finanzas.paz | Adj: Liquidacion.docm`
`WINWORD.EXE → powershell.exe`
`-nop -w hidden -enc <base64>`
`Network: billing-check-update.net`
	`User: compras.vera | Parent: chrome.exe`
	`Descargó: Factura_2026.exe`
	`Ejecutó desde Downloads`
	`→ Scheduled task + sync-check-cloud.net`
		`User: legal.romero`
		`URL: sharepoint-security-login.com`
		`Login: Success  MFA: Success`
		`New Device  |  Mailbox rule creada`

⚠ Word ejecutó PS con parámetros ocultos. Usuario no técnico, tema financiero.	⚠ Archivo descargado por usuario, ejecutado. Persistencia y comunicación externa.	⚠ No hay malware en endpoint. Compromiso de cuenta por phishing.
→ Escalar. Revisar si otros usuarios recibieron el mismo correo.	*→ Escalar con evidencia de ejecución y comportamiento posterior.*	*→ Escalar para identidad, sesiones y mailbox.*